מפרט הודעת אימות הטלפון לטכנאי שנושאת את הודעת הפרטיות הקצרה

מסמך	מפרט הודעת אימות הטלפון לטכנאי שנושאת את הודעת הפרטיות הקצרה
נתיב המקור	docs/privacy/technician-verification-message-spec.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

מפרט בלבד (אנגלית): איך המערכת מזהה טכנאי ומוסיפה לו את שורת הפרטיות בהודעת אימות המספר.

Spec: technician-only phone-verification message that carries the short notice

Status: IMPLEMENTED in PRIVTEXT-293 (release target 2.9.3). One deviation from section 3: two variants, `verify_technician` (no contact line) and `verify_technician_contact` (adds the verify_privacy last line), because a fixed label line ("Privacy questions:") does not drop out when the contact is unset; the shared definition is `access_grants.TECHNICIAN_SQL` / `is_technician`, used by `needs_review.idle_rows` too. Wording is pending legal review (see technician-notice-final.md). Basis: `origin/main` 586f191b3, read by code; paths are under `smplwise_vms/backend/smplwise/`. Decision 2 of 2026-10-18: the short notice (`access_grants.NOTICE_SHORT`) reaches the technician in the number-confirmation message.

1. The real code path

1. A number is confirmed by `services/tickets/phone_verify.py`: `send_code` (called by `admin_send` for a manager, `my_send` for a signed-in user) builds `extra = _privacy_variant(conn, target)` and enqueues `purpose="phone_verify"` with `**extra` (template id and params) through `messaging.RUNTIME.enqueue`.
2. At send time the outbox renders the FIXED starter for the purpose: `message_templates.fixed_starter("phone_verify", template_id, lang)`. The plain text is `STARTERS["phone_verify"]`; code-owned variants live in `FIXED_STARTERS` (`portal_code`, `verify_privacy`) and are whitelisted per purpose by `FIXED_VARIANTS`. Variants are never editable or storable.
3. `_privacy_variant` today returns `{}` for a signed-in user's row (`target["user_id"]`), and otherwise a `starter:verify_privacy` variant only when the installation set a privacy contact (`privacy_org.identity(conn).contact`). It does not know who the person is: a vendor contact and a technician look the same.
4. The vendor-added technician flow (`access_arrival.py`, `access_pending_contacts`) ends with the technician confirming his own number through this same `phone_verify` path (`phone_confirmed_via = 'code'`).

So the message is shared and no technician flag exists on the contact row (`ticket_contacts` has `kind`, `employee`, `user_id`, `vendor_id`, no role).

2. How to tell a technician from another directory contact

The distinction already exists as a query, in `services/needs_review.py` `idle_rows`: a technician is a `ticket_contacts` row with `kind='person'`, `user_id IS NULL`, `employee` falsy, not erased, and at least one of

- an `access_pending_contacts` row with `accepted_at` set (a vendor-added technician a manager accepted),
- an `access_person_links` row with `subject_kind='contact'`,
- an `access_grants` row with `subject_kind='contact'`.

(A pending, not yet accepted technician is `active = 0` and `phone_verify._target` already refuses an inactive row, so he never reaches the send.)

Proposed home: one function `access_grants.is_technician(conn, contact_id) -> bool` (or `needs_review.technician_ids`) sharing that EXISTS clause, so the two cannot drift; `phone_verify._privacy_variant` calls it for rows with no `user_id`. It must be a lazy import (`access_grants` already imports `phone_verify`; see `access_grants.py` line ~566).

Why not a simpler signal: `vendor_id` is set for vendor contacts and technicians alike; `access_person_links` alone misses a technician who has not been linked yet (the number is confirmed before the first grant is approved in some flows); a grant alone has the same gap. A new column `ticket_contacts.is_technician` would need a migration and backfill, and would be a second source of truth: not recommended.

Open point for the owner: a vendor contact who is also given a grant IS a technician under this definition and would get the notice. That is correct (he is being let into the building), but the first number confirmation of a person who only later receives a grant gets the plain message. The notice n2 on the arrival page still covers him; the short notice then arrives in the code message instead (`TEMPLATES`, already has the one-line notice).

3. Proposed variant

New code-owned variant `verify_technician` in `FIXED_STARTERS`, added to `FIXED_VARIANTS["phone_verify"]`. Body = the existing verification text, then the short notice verbatim, then (only when the installation set a contact) the existing privacy-question line. Placeholders: `{organization}` (line dropped when unset), `{code}`, `{privacy_contact}` (line dropped when unset; `render` already drops a line that renders empty). No link, no other placeholder.

lang	body
he	{organization} קוד לאימות מספר הטלפון: {code} הקוד בתוקף 10 דקות. אין למסור אותו לאחרים. אם לא ביקשתם אימות, התעלמו מההודעה. שמך, מספר הטלפון שלך ורישומי הכניסה שלך (שעה ודלת) נשמרים לצורך אבטחת המבנה בלבד, עד שהארגון מוחק אותם. לעיון, לתיקון או למחיקה: מנהל המבנה. שאלות בנושא פרטיות: {privacy_contact}
en	{organization} Phone number verification code: {code} Valid for 10 minutes. Do not share it. If you did not ask for this, ignore this message. Your name, phone number and entry records (time and door) are kept for building security only, until the organisation deletes them. To see, correct or delete them: the building manager. Privacy questions: {privacy_contact}
ar	{organization} رمز التحقق من رقم الهاتف: {code} صالح لمدة 10 دقائق. لا تشاركه مع أحد. إذا لم تكن أنت من بادر بالتحقق، تجاهل هذه الرسالة. يُحفظ اسمك ورقم هاتفك وسجلّ عمليات دخولك (الوقت والباب) لأغراض أمن المبنى فقط، إلى أن تحذفها المؤسسة. للاطلاع عليها أو تصحيحها أو حذفها: مدير المبنى. لأسئلة الخصوصية: {privacy_contact}

lang	body

ru	`{organization}`
	`Код подтверждения номера телефона: {code}`
	`Действует 10 минут. Никому его не сообщайте. Если вы не запрашивали код, проигнорируйте это сообщение.`
	`Ваше имя, номер телефона и данные о ваших входах (время и дверь) хранятся только для обеспечения безопасности здания до их удаления организацией. Ознакомление, исправление или удаление — через управляющего зданием.`
	`Вопросы о конфиденциальности: {privacy_contact}`

Notes

- When `{organization}` is set, the notice's "the building manager" and "the organisation" stay as written (the organisation line above already names it); decision 1 (organisation name + "the building manager") is satisfied by the first line plus the privacy line.
- The Arabic message starts with the organisation name when set, otherwise with Arabic text: the first strong character is Arabic or the organisation's own script. Check the direction on a real phone (owner, lab); no bidi control characters are added.
- Length: the longest rendering (ru, organisation and contact set) is roughly 520 characters against `RENDERED_MAX = 1000`; the test below enforces it.
- Single source of the notice wording: build the notice part of each body from `access_grants.NOTICE_SHORT[lang]` when `FIXED_STARTERS` is assembled, or assert equality in a test. Prefer the test (importing `access_grants` from `message_templates` at import time is a cycle risk).

4. Where the lookup lives

- `phone_verify._privacy_variant(conn, target)`: new first branch after the `user_id` guard: `if access_grants.is_technician(conn, target["id"]): return {"template_id": "starter:verify_technician", "params": {organization, privacy_contact if set}}`; else the current behaviour. The technician branch applies whether or not a privacy contact is set (decision 2 asks for the notice unconditionally for technicians).
- `message_templates.py`: the new `FIXED_STARTERS["verify_technician"]` entry and the `FIXED_VARIANTS` set.
- No migration, no setting, no UI. The feature `access.external_grants` stays OFF; the lookup returns false for everyone while there are no grants, links or accepted pending rows, so with the flag off every message is byte-identical to today.
- Audit: add `technician_notice: true` to the details of `ticket.contact.phone_verify_send` (no text, no number).

5. Tests to add (negative first)

1. `test_a_vendor_contact_never_gets_entry_records` (the key one): a plain vendor contact, and a vendor contact whose only link is to a ticket, render the `phone_verify` message without `NOTICE_SHORT` text and without the words "entry records" / "רישומי הכניסה" in any language, with and without a privacy contact set.
2. `test_a_signed_in_user_verifying_their_number_gets_the_fixed_text`: `user_id` set, technician-looking links present: still `{}`.

3. `test_is_technician_matches_needs_review`: one fixture set with all four cases (accepted pending, link, grant, none) asserting `is_technician` equals membership in `needs_review.idle_rows` source set; an unaccepted or rejected pending row and an erased contact are false.
4. `test_the_technician_variant_renders_in_every_language`: four languages; contains the code, `NOTICE_SHORT[lang]` verbatim, no `{`, own-script check (Hebrew letters only in he, Arabic only in ar, Cyrillic only in ru, ASCII-only apart from the organisation name in en), no `http`/`www`, length under `RENDERED_MAX`, line dropped when the organisation or contact is unset.
5. `test_the_variant_set_is_code_owned`: `fixed_starter("phone_verify", "starter:verify_technician", lang)` works; a stored template id naming it for another purpose is ignored; the key set is `{he,en,ar,ru}`; `tp.problems("phone_verify", body.replace("{privacy_contact}", "x")) == []` as in `test_the_fixed_code_variants_are_pinned_valid_and_name_the_organisation` (update its expected key set).
6. Update `test_privacy_org.py` `test_a_name_alone_does_not_change_the_verification_message`: still true for a non-technician; add the technician counterpart.
7. End to end (fake transport): a vendor-added technician accepted by a manager receives the technician variant on the arrival-page number confirmation; the audit row carries `technician_notice` and no text or number.

6. Risks

- **Vendor contacts must not get "entry records"** (test 1). The definition must stay conservative: false unless a grant, a link or an accepted pending row exists.
- **Definition drift**: two copies of the EXISTS clause would diverge; keep one function and test 3.
- **Lookup cost and import cycle**: one indexed query per send; lazy import of `access_grants` inside the function.
- **Wording ownership**: the same sentence now lives in two places (`NOTICE_SHORT` and the template); test 4 must assert equality, and a change needs counsel's review of both (C2, C3).
- **Arabic/Russian**: not native-reviewed; check how the message lays out on a real phone (RTL start, organisation name in Hebrew script in an Arabic message).
- **Retention claim**: "until the organisation deletes them" is only as true as the organisation's manual process (README, mismatch 5).
- **First-contact timing**: a technician whose number is confirmed before any grant/link/accepted-pending row exists gets the plain message (section 2).

7. Effort

About half a day of implementation plus runner time: roughly 40-50 lines of product code (helper, variant branch, four templates, audit field) and 120-150 lines of tests. Not under the 30-line bar, and it touches the shared verification path, so it is left as a spec for a separate, gated task. Gate tier: S plus the tickets message and access suites.